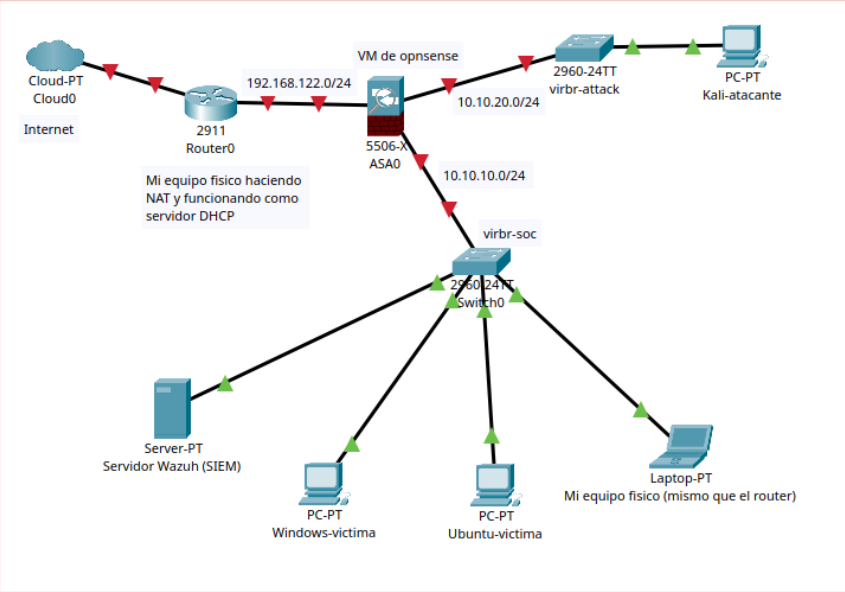
Write-up técnico

Laboratorio SOC casero

Despliegue de Wazuh, Suricata y OPNsense sobre KVM
y análisis de escenarios de ataque



Adolfo Nogués López

Ingeniería Informática – Universidad de Almería

`github.com/ualanl248`

Borrador v0.1 • 2 de noviembre de 2026

Resumen

Se ha desplegado un laboratorio SOC sobre KVM en un único portátil, con Wazuh 4.14 como SIEM, OPNsense como cortafuegos entre tres redes aisladas y Suricata como IDS de red. Hay dos víctimas monitorizadas (Windows 10 con Sysmon y Ubuntu Server) y una máquina atacante (Kali) en una red separada, de modo que todo el tráfico ofensivo atraviesa el cortafuegos.

Sobre este entorno se han ejecutado escenarios de ataque mapeados a MITRE ATT&CK y se ha documentado, para cada uno, la telemetría generada, la regla que lo detecta, la cronología, la respuesta y los huecos de detección.

#	Escenario	MITRE	Detectado
1	Escenario1	Codigo	**Sí**/no/pendiente
2	Escenario2	Codigo	**Sí**/no/pendiente
3	Escenario3	Codigo	**Sí**/no/pendiente

Tabla 1: Resultados en una línea por escenario

Hallazgos principales:

- Hallazgo1
- Hallazgo2

Pendiente

Resumen corto de un minnuto aprox.

Índice

Resumen i

1 Introducción 1
- 1.1 Motivación . . . 1
- 1.2 Objetivos . . . 1
- 1.3 Alcance y limitaciones . . . 1
- 1.4 Herramientas utilizadas . . . 2
- 1.5 Estructura del documento . . . 2

2 Arquitectura y decisiones de diseño 3
- 2.1 Topología . . . 3
- 2.2 Flujo de la telemetría . . . 4

3 Despliegue 5
- 3.1 Resumen de las configuraciones . . . 5
- 3.2 Conjuntos de reglas de Suricata . . . 5
- 3.3 Problemas encontrados y soluciones . . . 6
- 3.4 Instantáneas . . . 6

4 Escenarios de ataque y respuesta 7
- 4.1 Metodología . . . 7
- 4.2 Escenario 1: Fuerza bruta contra SSH . . . 7
  - 4.2.1 Ejecución . . . 7
  - 4.2.2 Telemetría . . . 8
  - 4.2.3 Detección . . . 8
  - 4.2.4 Investigación . . . 9
  - 4.2.5 Respuesta . . . 9
  - 4.2.6 Huecos y mejoras . . . 9
- 4.3 Escenario 2: Respuesta HTTP con salida de id como root . . . 9
  - 4.3.1 Ejecución . . . 10
  - 4.3.2 Telemetría . . . 10
  - 4.3.3 Detección . . . 10
  - 4.3.4 Investigación . . . 11
  - 4.3.5 Respuesta . . . 11
  - 4.3.6 Huecos y mejoras . . . 11
- 4.4 Escenario 3: Escaneo de puertos desde Kali . . . 12
  - 4.4.1 Ejecución . . . 12
  - 4.4.2 Telemetría . . . 12
  - 4.4.3 Detección . . . 12
  - 4.4.4 Investigación . . . 12
  - 4.4.5 Respuesta . . . 12
  - 4.4.6 Huecos y mejoras . . . 13

5 Cobertura de detección y afinado 14
- 5.1 Matriz de cobertura . . . 14
- 5.2 Reglas y ajustes propios . . . 14

6 Conclusiones **15**
6.1 Resultados . . . 15
6.2 Dificultades encontradas . . . 15
6.3 Lecciones aprendidas . . . 15
6.4 Trabajo futuro . . . 15

Bibliografía **16**

A Instalación paso a paso **17**
A.1 Preparación del host: KVM y redes virtuales . . . 17
A.2 OPNsense: router y cortafuegos . . . 17
A.3 Wazuh: servidor SIEM . . . 19
A.4 Víctima Windows 10: Sysmon y agente Wazuh . . . 21
A.4.1 Sysmon . . . 22
A.4.2 OpenSSH Server . . . 24
A.4.3 Agente Wazuh . . . 24
A.5 Suricata en OPNsense e integración con Wazuh . . . 25
A.6 Víctima Linux: Ubuntu Server . . . 27
A.7 Red de ataque y Kali Linux . . . 28

B Comandos de gestión del laboratorio **31**

C Configuraciones **32**
C.1 Red attack de libvirt . . . 32
C.2 Agente Wazuh en Windows . . . 32
C.3 Reglas locales de Wazuh . . . 32

Índice de figuras

2.1 Topología del laboratorio (modelada en Packet Tracer) 3

3.1 Estado final: agentes de Windows, OPNsense y Ubuntu registrados en Wazuh 5

4.1 Acceso SSH legítimo a la víctima (comprobación previa) 8
4.2 Alertas en Wazuh: fallos de inicio de sesión (60122) y bloqueo de cuenta (60115) 8
4.3 Alerta en Suricata (OPNsense) 10
4.4 La misma alerta reenviada a Wazuh por el agente de OPNsense 11

A.1 Esquema lógico de las redes y del direccionamiento 17
A.2 Redes virtuales activas en libvirt 17
A.3 Creación de la VM de OPNsense con virt-install 17
A.4 Instalador de OPNsense 26.7 (UFS) 18
A.5 Aviso del instalador por RAM inferior a 3 GB 18
A.6 Progreso de la instalación 18
A.7 Asignación de interfaces WAN y LAN 19
A.8 Configuración de la LAN (10.10.10.1/24) y del servidor DHCP (.100–.200) 19
A.9 Resumen de direcciones de OPNsense 19
A.10 Instantánea opnsense-base tras la configuración 19
A.11 Configuración de red estática del servidor Wazuh 20
A.12 Lanzamiento del instalador de Wazuh 20
A.13 Instantánea wazuh-base con Wazuh funcionando 21
A.14 Instalación de Windows 10 Pro 21
A.15 Creación del usuario local Victima 22
A.16 Windows obtiene IP por DHCP de OPNsense y sale a Internet 22
A.17 Instantánea windows-limpio 22
A.18 Instalación de Sysmon 23
A.19 Servicio Sysmon64 en ejecución y primeros eventos 23
A.20 Evento Sysmon ID 1 (creación de proceso) en detalle 24
A.21 Instalación y arranque de OpenSSH Server con PowerShell como shell por defecto . . . 24
A.22 Agente Wazuh instalado y arrancado 25
A.23 Instantánea windows-monitorizado 25
A.24 Ajustes generales de Suricata en OPNsense 26
A.25 Selección de rulesets 26
A.26 Reglas cargadas tras descargar los conjuntos 27
A.27 Instalación del plugin os-wazuh-agent 27
A.28 IP estática 10.10.10.20 en ubuntu-victima 28
A.29 Creación de la red attack 29
A.30 Regla de cortafuegos para la red ATTACK en OPNsense 29
A.31 Configuración de red en Kali 30
A.32 Kali alcanza su puerta de enlace e Internet a través de OPNsense 30

Índice de tablas

1 Resultados en una línea por escenario i

1.1 Características del equipo anfitrión 1
1.2 Herramientas y versiones del laboratorio 2

2.1 Redes virtuales del laboratorio 3
2.2 Inventario de máquinas virtuales 4

3.1 Resumen del despliegue 5
3.2 Problemas encontrados durante el despliegue 6
3.3 Instantáneas de las máquinas virtuales 6

4.1 Ficha resumen del escenario 7
4.2 Cronología del escenario 9
4.3 Ficha resumen del escenario 9
4.4 Cronología del escenario 11
4.5 Ficha resumen del escenario 12
4.6 Cronología del escenario 12

5.1 Cobertura de técnicas MITRE ATT&CK probadas 14
5.2 Registro de ajustes de detección 14

Índice de listados

4.1 Ataque de fuerza bruta SSH 7
4.2 Alerta Wazuh 60115 (bloqueo de cuenta), JSON resumido 8
4.3 Consulta en Wazuh (DQL) para aislar el escenario 8
4.4 Petición desde la víctima 10
4.5 Evento EVE de Suricata, resumido 10
4.6 Escaneo desde Kali 12
4.7 Evento en bruto 12
5.1 Ejemplo: regla local de Wazuh 14
A.1 Creación de la VM de Wazuh 19
A.2 Instalación all-in-one de Wazuh 20
A.3 Creación de la VM Windows 10 21
A.4 Instalación de Sysmon (PowerShell como administrador) 22
A.5 Instalación del agente Wazuh en Windows 24
A.6 Creación de la VM ubuntu-victima 27
A.7 Definición de la red attack 28
A.8 Configuración de red estática en Kali 29
B.1 Gestión de VM con virsh 31
C.1 configs/libvirt/attack.xml 32

1 | Introducción

1.1 Motivación

Este documento recoge el montaje y la puesta a prueba de un laboratorio SOC (Security Operations Center) casero, desplegado íntegramente con máquinas virtuales sobre un portátil con Ubuntu. El objetivo es reproducir a pequeña escala el trabajo de un analista de nivel 1: recoger telemetría de los equipos, generar ataques controlados y comprobar si se detectan, cómo se detectan y qué se puede hacer como respuesta.

Pendiente

Breve explicación de las motivaciones del proyecto

1.2 Objetivos

- Desplegar un SIEM/XDR funcional (Wazuh) en una red aislada.
- Segmentar la red con un cortafuegos (OPNsense) y añadir un IDS de red (Suricata).
- Monitorizar equipos víctima Windows y Linux con agentes y Sysmon.
- Ejecutar escenarios de ataque desde una red de atacante separada (Kali) y documentar detección, análisis y respuesta, mapeados a MITRE ATT&CK.

1.3 Alcance y limitaciones

- Entorno de laboratorio sin tráfico real de usuarios: el volumen de eventos y falsos positivos no es representativo de producción.
- Recursos limitados del host (RAM), lo que condiciona cuántas VM pueden estar encendidas a la vez.
- Todos los ataques se ejecutan contra máquinas propias dentro de redes aisladas.

Hardware del equipo anfitrión

Procesador	Intel Core i7-8750H @ 2.20 GHz (6 núcleos / 12 hilos)
Memoria RAM	32 GB DDR4 en dos módulos de 16 GB (2667 MT/s)
Almacenamiento	SSD de 234 GB
Gráfica	Integrada en el procesador
Hipervisor	KVM/QEMU con libvirt sobre Ubuntu 26.04

Tabla 1.1: Características del equipo anfitrión

1.4 Herramientas utilizadas

Herramienta	Versión	Función en el laboratorio
KVM / libvirt / virt-manager	–	Hipervisor y redes virtuales del host
OPNsense	26.7	Router, cortafuegos, NAT y DHCP entre redes
Suricata (en OPNsense)	–	IDS de red sobre la interfaz LAN
Wazuh	4.14	SIEM/XDR: indexer, manager y dashboard
Sysmon	15.x	Telemetría avanzada de procesos en Windows
Windows 10 Pro	22H2	Víctima Windows (agente Wazuh + Sysmon)
Ubuntu Server	26.04	Servidor Wazuh y víctima Linux
Kali Linux	–	Máquina atacante en red separada

Tabla 1.2: Herramientas y versiones del laboratorio

1.5 Estructura del documento

El capítulo 2 describe la arquitectura y las decisiones de diseño. El capítulo 3 resume el despliegue y los problemas encontrados. El capítulo 4, núcleo del documento, recoge los escenarios de ataque con su telemetría, detección, investigación y respuesta. El capítulo 5 reúne la cobertura de detección y los ajustes realizados, y el capítulo 6 cierra con lo aprendido. Los anexos contienen la instalación paso a paso (A), los comandos de gestión (B) y las configuraciones (C).

2 | Arquitectura y decisiones de diseño

2.1 Topología

El laboratorio se compone de tres redes virtuales de libvirt. La red default (NAT del host) hace de Internet para OPNsense. La red soc-lab es la LAN interna donde se encuentran el SIEM y las víctimas. Y la red attack aísla a la máquina atacante.

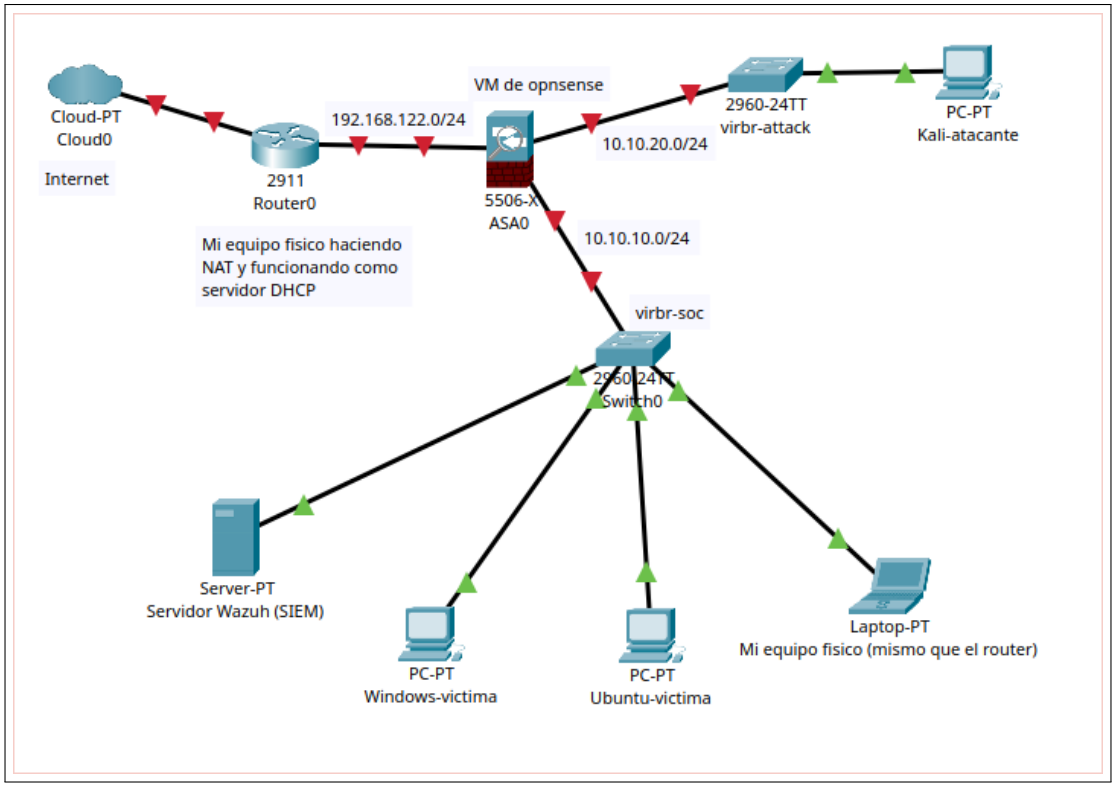


Figura 2.1: Topología del laboratorio (modelada en Packet Tracer)

Red libvirt	Puente	Subred	Uso
default	virbr0	192.168.122.0/24	WAN de OPNsense (NAT + DHCP de libvirt)
soc-lab	virbr-soc	10.10.10.0/24	LAN: SIEM y víctimas
attack	virbr-attack	10.10.20.0/24	Red del atacante (Kali)

Tabla 2.1: Redes virtuales del laboratorio

VM	IP	RAM	vCPU	Disco	Rol
opnsense	10.10.10.1 / 10.10.20.1	2 GB	2	20 GB	Router, firewall, DHCP, Suricata
wazuh	10.10.10.10	8 GB	4	50 GB	SIEM
windows10	10.10.10.130 (DHCP)	4 GB	2	50 GB	Víctima Windows con Sysmon y agente
ubuntu-victima	10.10.10.20	2 GB	1	15 GB	Víctima Linux con agente
kali	10.10.20.10	4GB	2	80GB	Atacante
host	10.10.10.254	–	–	–	Administración y acceso al dashboard

Tabla 2.2: Inventario de máquinas virtuales

2.2 Flujo de la telemetría

- Endpoint Windows: registro de seguridad y Sysmon → agente Wazuh → manager (10.10.10.10).
- Endpoint Linux: auth.log, syslog → agente Wazuh → manager.
- Red: Suricata en la LAN de OPNsense → eve.json → agente Wazuh de OPNsense → manager.

3 | Despliegue

Este capítulo resume el despliegue y se centra en lo que no está en la documentación oficial. El paso a paso completo, con todas las capturas, está en el anexo A.

3.1 Resumen de las configuraciones

Componente	Configuración relevante	Detalle
OPNsense	WAN vtnet0 (DHCP), LAN vtnet1 10.10.10.1/24, DHCP .100–.200, interfaz ATTACK 10.10.20.1/24	A.2
Wazuh	All-in-one 4.14, IP estática 10.10.10.10	A.3
Windows 10	Usuario local Victima, Sysmon, OpenSSH Server, agente Wazuh	A.4
Suricata	IDS (PCAP live) en LAN, promiscuo; rulesets abuse.ch y ET open; plugin os-wazuh-agent	A.5
Ubuntu víctima	IP estática 10.10.10.20, agente Wazuh	A.6
Kali	Red attack, 10.10.20.10, puerta de enlace OPNsense	A.7

Tabla 3.1: Resumen del despliegue

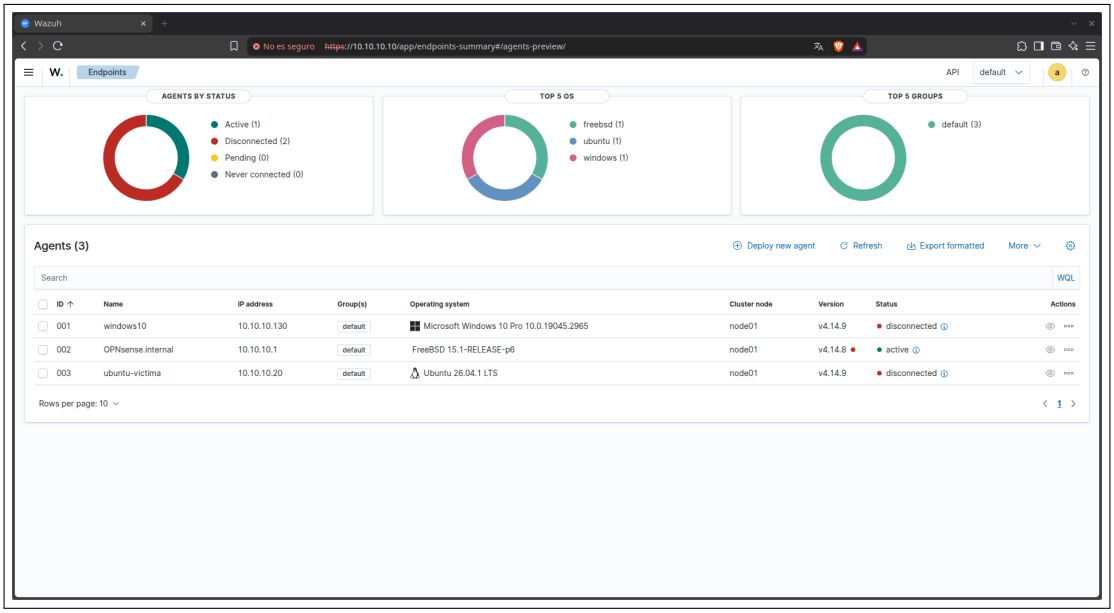


Figura 3.1: Estado final: agentes de Windows, OPNsense y Ubuntu registrados en Wazuh

3.2 Conjuntos de reglas de Suricata

- Reputación / listas negras: abuse.ch SSL Fingerprint Blacklist, abuse.ch SSL IP Blacklist, abuse.ch ThreatFox, abuse.ch URLhaus; ET open botcc, ET open compromised y ET open drop.
- Detección de ataques: ET open emerging-attack_response, emerging-scan, emerging-exploit, emerging-malware, emerging-policy, emerging-dns y emerging-web_client.
- Excluidos explícitamente: emerging-info y emerging-hunting, por generar un volumen elevado de alertas sobre actividad legítima.

- Configuración del motor: modo IDS (PCAP live, sin bloqueo) sobre la interfaz LAN; HOME_NET restringido a 10.10.10.0/24, de modo que la red atacante (10.10.20.0/24), la WAN e Internet se consideran externas; actualización diaria de reglas programada.
- Validación: firma SID 2100498 (GPL ATTACK_RESPONSE id check returned root), disparada sirviendo la cadena uid=0(root) desde un servidor HTTP en el lado WAN (192.168.122.1:8000), ya que el dominio de prueba testmynids.org ha caducado. La alerta se recibe en Wazuh mediante el agente de OPNsense (regla 86601).
- Ajuste necesario: desactivar la descarga de hardware (CRC, TSO y LRO) en las interfaces de OPNsense; con las tarjetas virtio, Suricata no generaba alertas hasta aplicar este cambio.

3.3 Problemas encontrados y soluciones

Problema	Solución
El instalador de OPNsense pide 3 GB de RAM y la VM tiene 2 GB.	Se continúa con Proceed anyway; funciona para el volumen del laboratorio.
virt-install no reconoce el SO de la ISO de Ubuntu 26.04.	–osinfo detect=on,require=off (perfil genérico).
Primer intento de descarga de Sysmon devuelve BlobNotFound.	Reintentar la descarga desde download.sysinternals.com.
Kali no resuelve nombres (Temporary failure in name resolution).	IP, puerta de enlace y DNS estáticos con nmcli + regla en OPNsense para la red ATTACK.
Marcas de tiempo de Suricata desfasadas una hora.	OPNsense usa UTC; **Pendiente** indica si lo unificaste .

Tabla 3.2: Problemas encontrados durante el despliegue

Pendiente

Añade cualquier otro problema que recuerdes; es de lo más valioso del write-up.

3.4 Instantáneas

VM	Instantánea	Estado
opnsense	opnsense-base	Instalado y configurado
wazuh	wazuh-base	Wazuh 4.14 instalado y funcionando
windows10	windows-limpio	Windows recién instalado
windows10	windows-monitorizado	Sysmon + agente Wazuh funcionando

Tabla 3.3: Instantáneas de las máquinas virtuales

4 | Escenarios de ataque y respuesta

4.1 Metodología

Cada escenario parte de una hipótesis de detección ("si un atacante hace X, debería verse Y en la fuente Z") y sigue el ciclo de gestión de incidentes del NIST [1]:

1. Ficha e hipótesis: técnica MITRE ATT&CK [2], origen, objetivo y qué se espera ver.
2. Ejecución: comandos y evidencias desde la máquina atacante.
3. Telemetría: el evento en bruto tal como llega al SIEM.
4. Detección: la regla, firma o consulta que lo identifica y la alerta resultante.
5. Investigación: cronología de los hechos y su interpretación.
6. Respuesta: contención, erradicación y recuperación.
7. Huecos y mejoras: qué no se detectó, falsos positivos y ajustes.

Antes de cada escenario se restauran las instantáneas (tabla 3.3) para partir siempre del mismo estado.

4.2 Escenario 1: Fuerza bruta contra SSH

Técnica MITRE ATT&CK	T1110.001 – Brute Force: Password Guessing [3]
Origen del ataque	10.10.10.254 (host)
Objetivo	windows10 (10.10.10.130), OpenSSH Server, usuario victima
Fuente de detección	Wazuh – registro de seguridad de Windows
Reglas / firmas	60122 (fallo de inicio de sesión), 60115 (bloqueo de cuenta)
Severidad máxima	Nivel 9
Resultado	**Sí** detectado; la cuenta queda bloqueada

Tabla 4.1: Ficha resumen del escenario

Hipótesis de detección

Varios intentos de autenticación SSH fallidos contra la víctima Windows deberían generar eventos 4625 en el registro de seguridad, que Wazuh agrupa en alertas de fallo de inicio de sesión; si se alcanza el umbral de bloqueo, un evento 4740.

4.2.1 Ejecución

Pendiente

Comando exacto del ataque (p. ej. hydra -l victima -P lista.txt ssh://10.10.10.130) y captura desde el atacante.

Listado 4.1: Ataque de fuerza bruta SSH

```
# TODO: pega aquí el comando usado
```

```
PS C:\Users\Victima> whoami
desktop-5p6l22j\victima
PS C:\Users\Victima>
```

Figura 4.1: Acceso SSH legítimo a la víctima (comprobación previa)

4.2.2 Telemetría

Pendiente

Pega el JSON de una alerta 60122 y de la 60115 (Wazuh → Threat Hunting → abrir el evento → pestaña JSON). Quita lo que no aporte.

Listado 4.2: Alerta Wazuh 60115 (bloqueo de cuenta), JSON resumido

```
{
  "rule": { "id": "60115", "level": 9, "description": "User account locked out (multiple login errors)",
            "mitre": { "id": ["T1110"] } },
  "agent": { "name": "windows10", "ip": "10.10.10.130" },
  "data": { "win": { "system": { "eventID": "4740" },
            "eventdata": { "targetUserName": "TODO" } } }
}
```

4.2.3 Detección

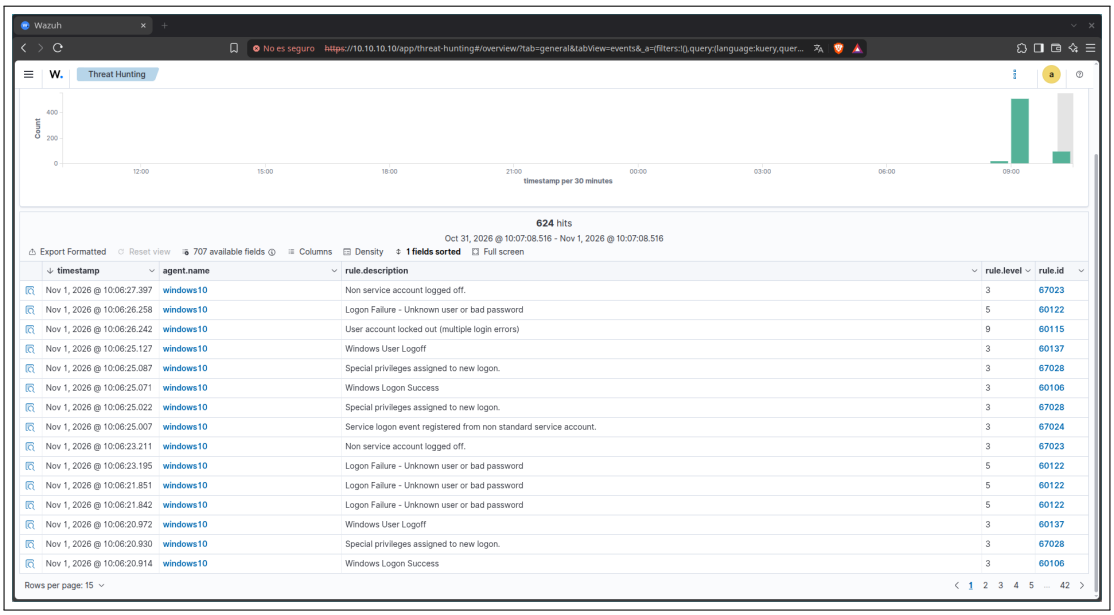


Figura 4.2: Alertas en Wazuh: fallos de inicio de sesión (60122) y bloqueo de cuenta (60115)

Listado 4.3: Consulta en Wazuh (DQL) para aislar el escenario

```
agent.name:windows10 and rule.id:(60122 or 60115)
```

4.2.4 Investigación

Hora	Equipo	Fuente / regla	Evento
10:06:2x	windows10	Wazuh 60122 / EID 4625	Primeros fallos de inicio de sesión desde 10.10.10.254
10:06:26	windows10	Wazuh 60115 / EID 4740	Cuenta bloqueada por exceso de intentos
Pendiente			

Tabla 4.2: Cronología del escenario

Pendiente

Interpreta: número de intentos, intervalo, tipo de logon (Logon Type 8/3), si hubo algún éxito (4624).

4.2.5 Respuesta

Pendiente

Contención aplicada o propuesta: bloqueo de 10.10.10.254 en OPNsense, Active Response de Wazuh (firewall-drop), autenticación por clave, restringir SSH a una red de administración.

4.2.6 Huecos y mejoras

Lección aprendida

La política de bloqueo de cuenta frena el ataque, pero también puede usarse para provocar una denegación de servicio a un usuario legítimo.

Pendiente

¿Se detectaría un password spraying lento (un intento por cuenta cada pocos minutos)?

4.3 Escenario 2: Respuesta HTTP con salida de id como root

Técnica MITRE ATT&CK	**Pendiente** Mapear (p. ej. T1059 o tratarlo como prueba de la cadena IDS)
Origen del ataque	windows10 (10.10.10.130)
Objetivo	Servidor HTTP en 192.168.122.1:8000
Fuente de detección	Suricata (OPNsense) → agente Wazuh de OPNsense
Reglas / firmas	SID 2100498 GPL ATTACK_RESPONSE id check returned root; Wazuh 86601
Severidad máxima	Nivel 3 (Wazuh)
Resultado	**Sí** detectado en Suricata y reenviado a Wazuh

Tabla 4.3: Ficha resumen del escenario

Hipótesis de detección

Una respuesta HTTP que contenga uid=0(root), patrón típico tras obtener una shell privilegiada, debería disparar la firma ATTACK_RESPONSE de Suricata y llegar a Wazuh a través del agente de OPNsense.

4.3.1 Ejecución

Listado 4.4: Petición desde la víctima

```
PS C:\Users\Victima> curl.exe http://192.168.122.1:8000/uid.html
uid=0(root) gid=0(root) groups=0(root)
```

Pendiente

Añade cómo serviste uid.html en el host (p. ej. python3 -m http.server 8000).

4.3.2 Telemetría

Pendiente

Pega el evento EVE de Suricata (/var/log/suricata/eve.json en OPNsense) o el JSON de la alerta 86601 en Wazuh.

Listado 4.5: Evento EVE de Suricata, resumido

```
{
  "event_type": "alert", "src_ip": "192.168.122.1", "src_port": 8000,
  "dest_ip": "10.10.10.130", "dest_port": 49750, "proto": "TCP",
  "alert": { "signature_id": 2100498, "signature": "GPL ATTACK_RESPONSE id check returned root",
             "category": "TODO", "severity": 2 }
}
```

4.3.3 Detección

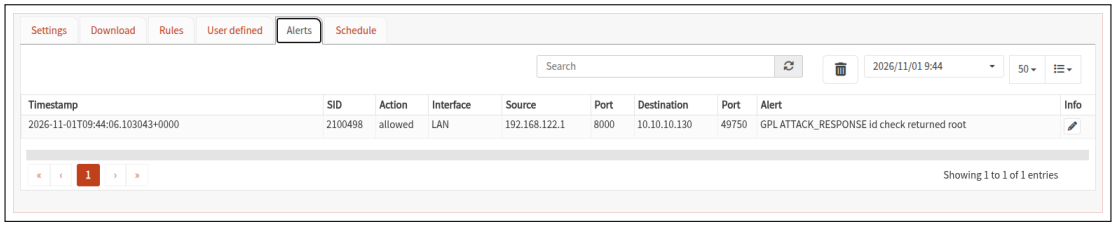


Figura 4.3: Alerta en Suricata (OPNsense)

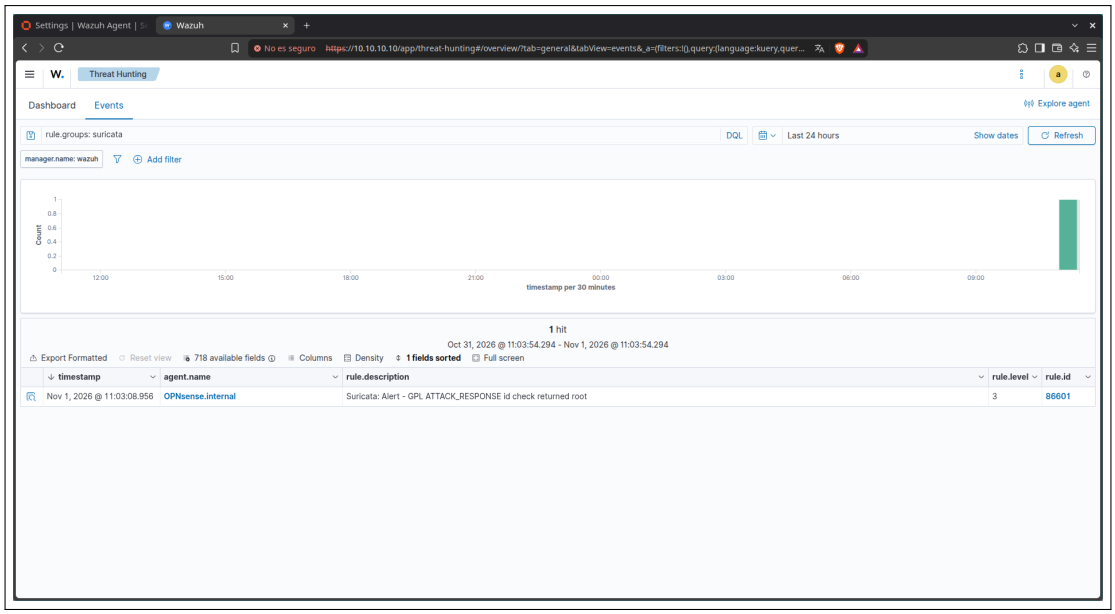


Figura 4.4: La misma alerta reenviada a Wazuh por el agente de OPNsense

4.3.4 Investigación

Hora	Equipo	Fuente / regla	Evento
09:44:06 UTC	opnsense	Suricata 2100498	Respuesta HTTP con uid=0(root) hacia 10.10.10.130
11:03:08	opnsense	Wazuh 86601	Alerta de Suricata indexada en Wazuh

Tabla 4.4: Cronología del escenario

Desfase horario

Las marcas de tiempo de Suricata aparecen con una hora de diferencia respecto a Wazuh porque OPNsense registra en UTC. Para correlacionar eventos hay que unificar la zona horaria de todas las fuentes.

Pendiente

Explica qué haría un analista para descartar un falso positivo (contexto del proceso en Sysmon EID 1 y EID 3 en la víctima, reputación del destino).

4.3.5 Respuesta

Pendiente

Respuesta aplicada o propuesta: pasar Suricata a modo IPS, bloquear el destino, aislar el equipo, revisar el proceso que hizo la petición.

4.3.6 Huecos y mejoras

Pendiente

La firma solo ve HTTP en claro: ¿qué pasaría con HTTPS? Nivel 3 en Wazuh es bajo para esta firma: ¿crearías una regla local que lo eleve?

4.4 Escenario 3: Escaneo de puertos desde Kali

Técnica MITRE ATT&CK	T1046 – Network Service Discovery
Origen del ataque	kali (10.10.20.10)
Objetivo	Red soc-lab (10.10.10.0/24)
Fuente de detección	Por completar
Reglas / firmas	Por completar
Severidad máxima	Por completar
Resultado	Pendiente

Tabla 4.5: Ficha resumen del escenario

Hipótesis de detección

Pendiente

Qué esperas ver y en qué fuente (p. ej. firmas ET SCAN de Suricata).

4.4.1 Ejecución

Listado 4.6: Escaneo desde Kali

```
# TODO: nmap ...
```

4.4.2 Telemetría

Listado 4.7: Evento en bruto

```
TODO
```

4.4.3 Detección

Pendiente

Regla o firma, consulta y captura de la alerta.

4.4.4 Investigación

Hora	Equipo	Fuente / regla	Evento
Pendiente			

Tabla 4.6: Cronología del escenario

4.4.5 Respuesta

Pendiente

Contención, erradicación y recuperación.

4.4.6 Huecos y mejoras

Pendiente

¿Se detecta un escaneo lento (-T1) o solo de puertos comunes?

5 | Cobertura de detección y afinado

5.1 Matriz de cobertura

Táctica	Técnica	Fuente	Regla / firma	Detectado
Credential Access	T1110.001 Password Guessing	Registro de seguridad de Windows	Wazuh 60122, 60115	Sí
–	Prueba de cadena IDS (uid=0(root))	Suricata → Wazuh	SID 2100498, Wazuh 86601	Sí
Discovery	T1046 Network Service Discovery	Suricata	–	Pendiente

Tabla 5.1: Cobertura de técnicas MITRE ATT&CK probadas

Pendiente

Opcional: exporta una capa de MITRE ATT&CK Navigator con las técnicas probadas y añádela como figura.

5.2 Reglas y ajustes propios

Pendiente

Documenta aquí cada regla local de Wazuh (local_rules.xml), cada firma desactivada o ajustada en Suricata y cada falso positivo encontrado, con el motivo. Ejemplo de formato:

Listado 5.1: Ejemplo: regla local de Wazuh

```
<group name="local,suricata,">
  <!-- Eleva la severidad de ATTACK_RESPONSE id check returned root -->
  <rule id="100100" level="12">
    <if_sid>86601</if_sid>
    <field name="alert.signature_id">^2100498$</field>
    <description>Suricata: respuesta con uid=0(root) (posible shell privilegiada)</description
    >
    <mitre><id>T1059</id></mitre>
  </rule>
</group>
```

Regla / firma	Cambio	Motivo
Pendiente		

Tabla 5.2: Registro de ajustes de detección

6 | Conclusiones

6.1 Resultados

Pendiente

Resume qué funciona: qué se detecta, qué no y con qué fuentes.

6.2 Dificultades encontradas

- Recursos limitados del host: OPNsense con 2 GB de RAM (el instalador recomienda 3 GB) y necesidad de alternar las VM encendidas.
- Diferencia de zona horaria entre OPNsense (UTC) y el resto de fuentes.

Pendiente

Añade el resto de problemas y cómo los resolviste.

6.3 Lecciones aprendidas

Pendiente

Lo que te llevas del proyecto, también de cara al Security+ y al trabajo en un SOC.

6.4 Trabajo futuro

- Pasar Suricata a modo IPS y probar el bloqueo en línea.
- Configurar respuestas automáticas (Active Response) en Wazuh.
- Añadir más escenarios: movimiento lateral, persistencia, exfiltración.
- Crear reglas y decodificadores propios en Wazuh.

Bibliografía

[1] Paul Cichonski, Tom Millar, Tim Grance, and Karen Scarfone. Computer security incident handling guide. Technical Report SP 800-61 Rev. 2, National Institute of Standards and Technology, 2012. https://doi.org/10.6028/NIST.SP.800-61r2.

[2] The MITRE Corporation. Mitre att&ck. https://attack.mitre.org/. Consultado en noviembre de 2026.

[3] The MITRE Corporation. Brute force: Password guessing (t1110.001). https://attack.mitre.org/techniques/T1110/001/. Consultado en noviembre de 2026.

[4] Wazuh Inc. Wazuh documentation. https://documentation.wazuh.com/current/. Consultado en noviembre de 2026.

[5] Deciso B.V. Opnsense documentation. https://docs.opnsense.org/. Consultado en noviembre de 2026.

[6] Open Information Security Foundation. Suricata user guide. https://docs.suricata.io/. Consultado en noviembre de 2026.

[7] Mark Russinovich and Thomas Garnier. Sysmon – sysinternals. https://learn.microsoft.com/sysinternals/downloads/sysmon. Consultado en noviembre de 2026.

[8] SwiftOnSecurity. sysmon-config: Sysmon configuration file template with default high-quality event tracing. https://github.com/SwiftOnSecurity/sysmon-config. Consultado en noviembre de 2026.

[9] libvirt project. libvirt: Virtual networking. https://libvirt.org/formatnetwork.html. Consultado en noviembre de 2026.

[10] testmynids.org. http://testmynids.org/. Consultado en noviembre de 2026.

A | Instalación paso a paso

Este anexo recoge el proceso completo de instalación con todas las capturas, como referencia para reproducir el laboratorio. El resumen y las decisiones están en los capítulos 2 y 3.

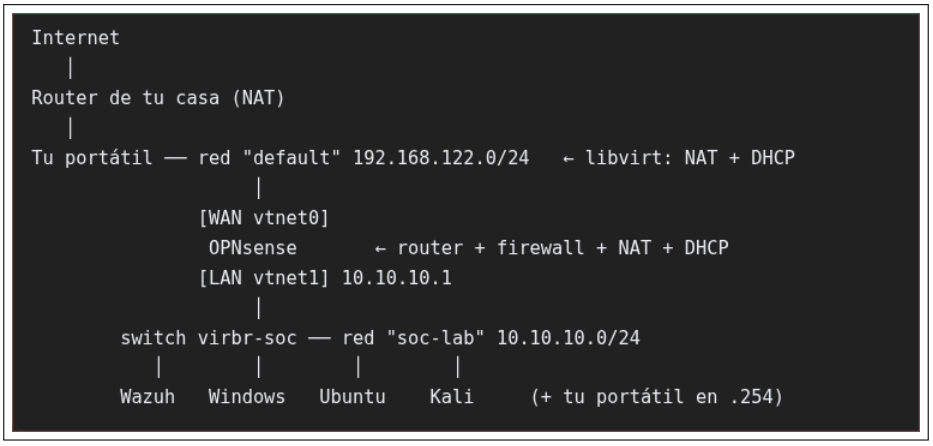


Figura A.1: Esquema lógico de las redes y del direccionamiento

A.1 Preparación del host: KVM y redes virtuales

Se instala KVM con libvirt y virt-manager en el Ubuntu anfitrión y se crea la red aislada soc-lab.

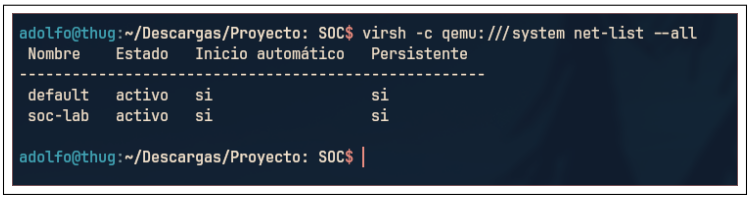


Figura A.2: Redes virtuales activas en libvirt

Pendiente

Añade el XML o los comandos con los que creaste la red soc-lab.

A.2 OPNsense: router y cortafuegos

OPNsense se instala con dos interfaces VirtIO: vtnet0 como WAN en la red default y vtnet1 como LAN en soc-lab.

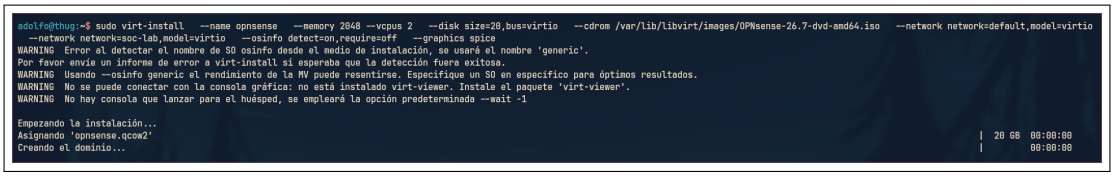


Figura A.3: Creación de la VM de OPNsense con virt-install

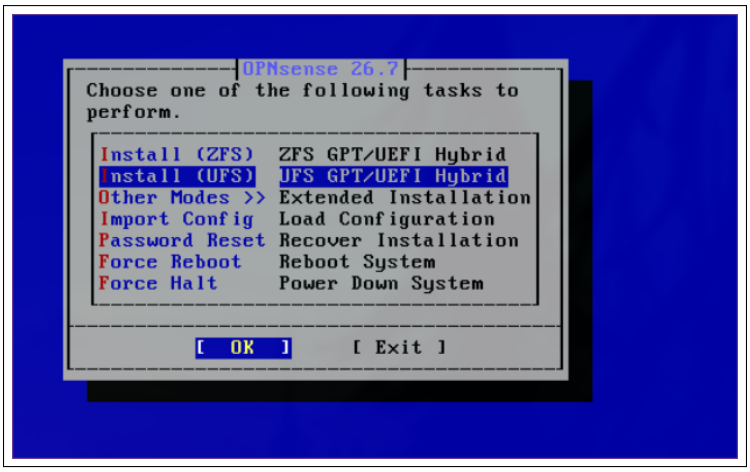


Figura A.4: Instalador de OPNsense 26.7 (UFS)

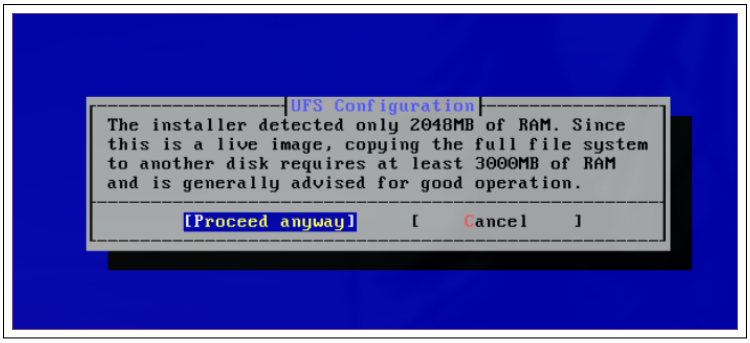


Figura A.5: Aviso del instalador por RAM inferior a 3 GB

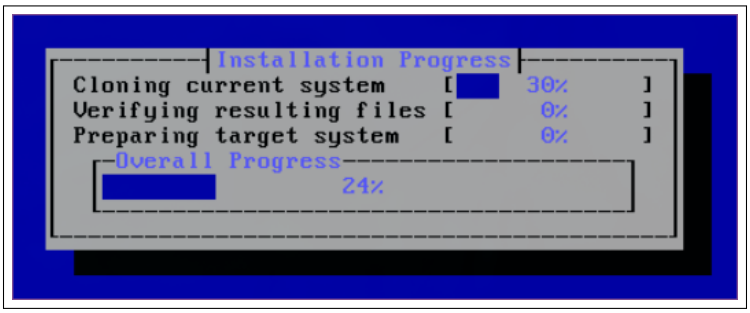


Figura A.6: Progreso de la instalación

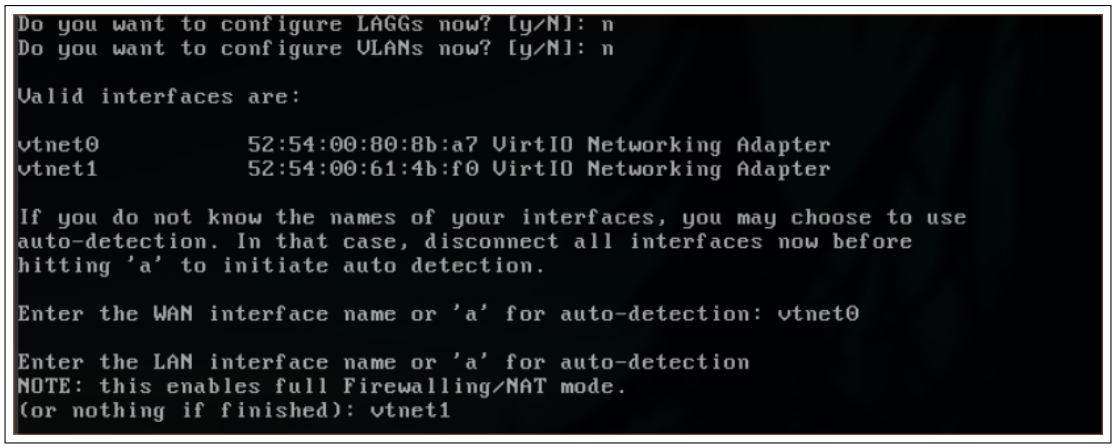


Figura A.7: Asignación de interfaces WAN y LAN

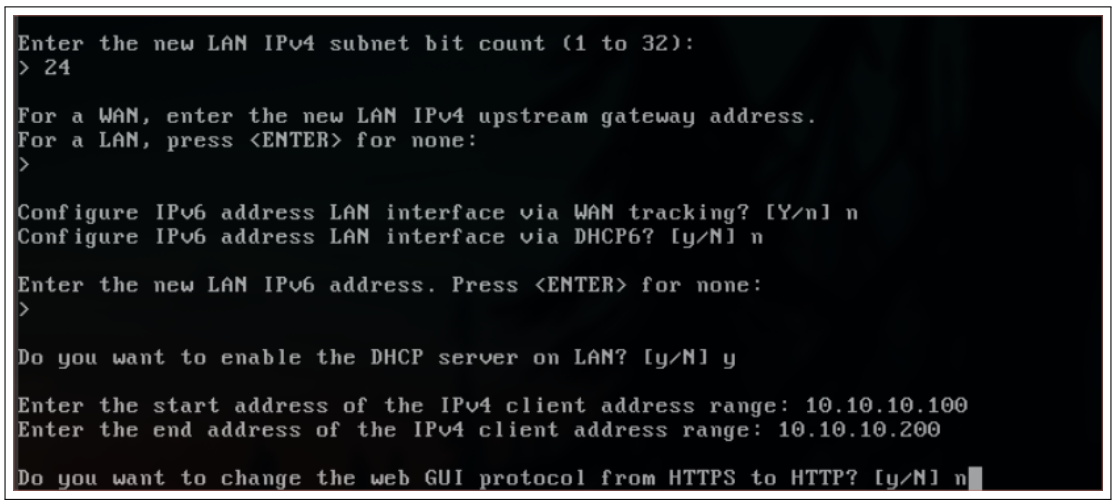


Figura A.8: Configuración de la LAN (10.10.10.1/24) y del servidor DHCP (.100–.200)

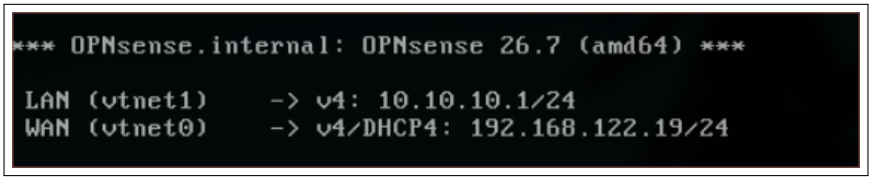


Figura A.9: Resumen de direcciones de OPNsense

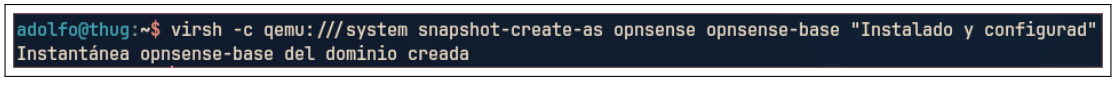


Figura A.10: Instantánea opnsense-base tras la configuración

A.3 Wazuh: servidor SIEM

Wazuh 4.14 se despliega en modo all-in-one sobre Ubuntu Server con IP estática 10.10.10.10.

Listado A.1: Creación de la VM de Wazuh

```
virt-install --connect qemu:///system \
```

```
  --name wazuh --memory 8192 --vcpus 4 \
  --disk size=50,bus=virtio \
  --cdrom /var/lib/libvirt/images/ubuntu-26.04.1-live-server-amd64.iso \
  --network network=soc-lab,model=virtio \
  --osinfo detect=on,require=off \
  --graphics spice --noautoconsole
```



Figura A.11: Configuración de red estática del servidor Wazuh

Listado A.2: Instalación all-in-one de Wazuh

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
sudo bash ./wazuh-install.sh -a -i
```

```
Running kernel seems to be up-to-date.

Restarting services...
 systemctl restart cron.service multipathd.service packagekit.service polkit.service ssh.service udisk
s2.service

Service restarts being deferred:
 systemctl restart ModemManager.service
 /etc/needrestart/restart.d/dbus.service
 systemctl restart networkd-dispatcher.service
 systemctl restart systemd-logind.service
 systemctl restart unattended-upgrades.service

No containers need to be restarted.

User sessions running outdated binaries:
 ubuntu @ session #1: login[1133]
 ubuntu @ session #4: apt[1600], bash[1471], sshd-session[1414], sudo[1597,1599]
 ubuntu @ user manager: (sd-pam)[1340]

No VM guests are running outdated hypervisor (qemu) binaries on this host.
ubuntu@wazuh:~$ clear
'xterm-kitty': unknown terminal type.
ubuntu@wazuh:~$ curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
ubuntu@wazuh:~$ sudo bash ./wazuh-install.sh -a -i
```

Figura A.12: Lanzamiento del instalador de Wazuh

```
adolfo@thug:~$ virsh -c qemu:///system snapshot-create-as wazuh wazuh-base "Wazuh 4.14 instalado y funcionando"
Instantánea wazuh-base del dominio creada
adolfo@thug:~$
```

Figura A.13: Instantánea wazuh-base con Wazuh funcionando

Seguridad

El instalador muestra la contraseña del usuario admin del dashboard en claro. No se incluye esa captura en el documento; si se añade, debe pixelarse antes.

A.4 Víctima Windows 10: Sysmon y agente Wazuh

Listado A.3: Creación de la VM Windows 10

```
virt-install --connect qemu:///system \
  --name windows10 --memory 4096 --vcpus 2 \
  --disk size=50,bus=sata \
  --cdrom /var/lib/libvirt/images/Win10_22H2_EnglishInternational_x64v1.iso \
  --network network=soc-lab,model=e1000e \
  --osinfo win10 --graphics spice --noautoconsole
virt-viewer -c qemu:///system --reconnect windows10 &
```

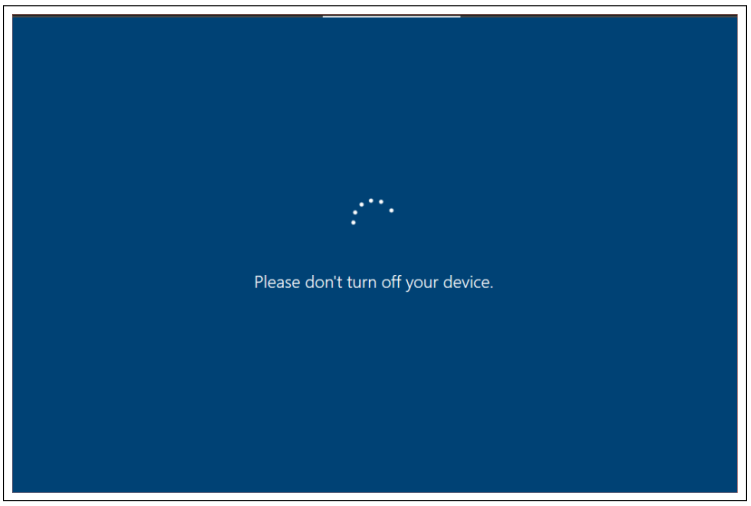


Figura A.14: Instalación de Windows 10 Pro

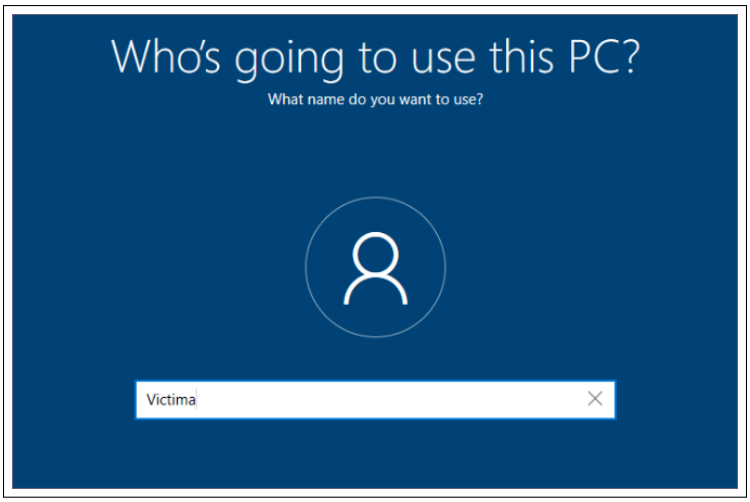


Figura A.15: Creación del usuario local Victima

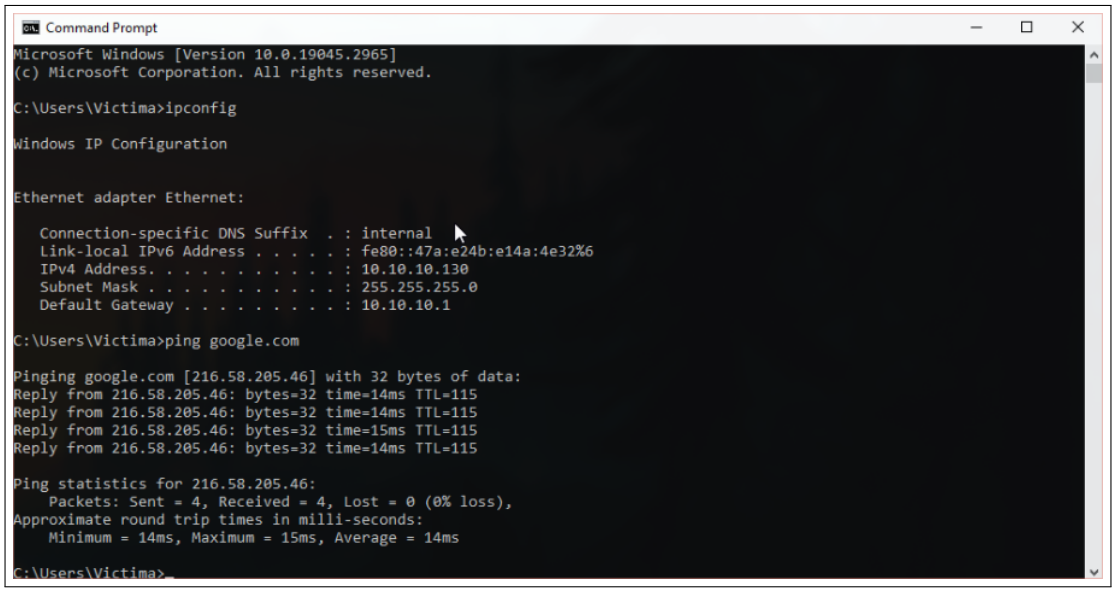


Figura A.16: Windows obtiene IP por DHCP de OPNsense y sale a Internet

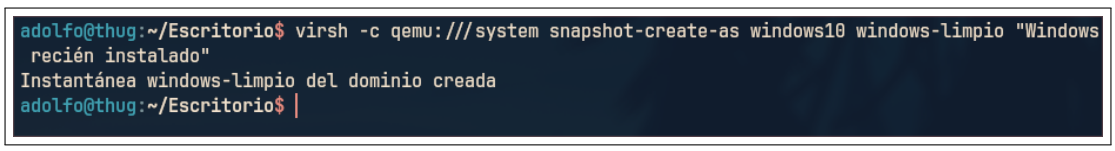


Figura A.17: Instantánea windows-limpio

A.4.1 Sysmon

Sysmon se instala con la configuración de SwiftOnSecurity [8].

Listado A.4: Instalación de Sysmon (PowerShell como administrador)

```
cd $env:TEMP
Invoke-WebRequest https://download.sysinternals.com/files/Sysmon.zip -OutFile Sysmon.zip
Expand-Archive Sysmon.zip -DestinationPath Sysmon -Force
Invoke-WebRequest https://raw.githubusercontent.com/SwiftOnSecurity/sysmon-config/master/
    sysmonconfig-export.xml -OutFile sysmonconfig.xml
```

```
.\Sysmon\Sysmon64.exe -accepteula -i sysmonconfig.xml
```

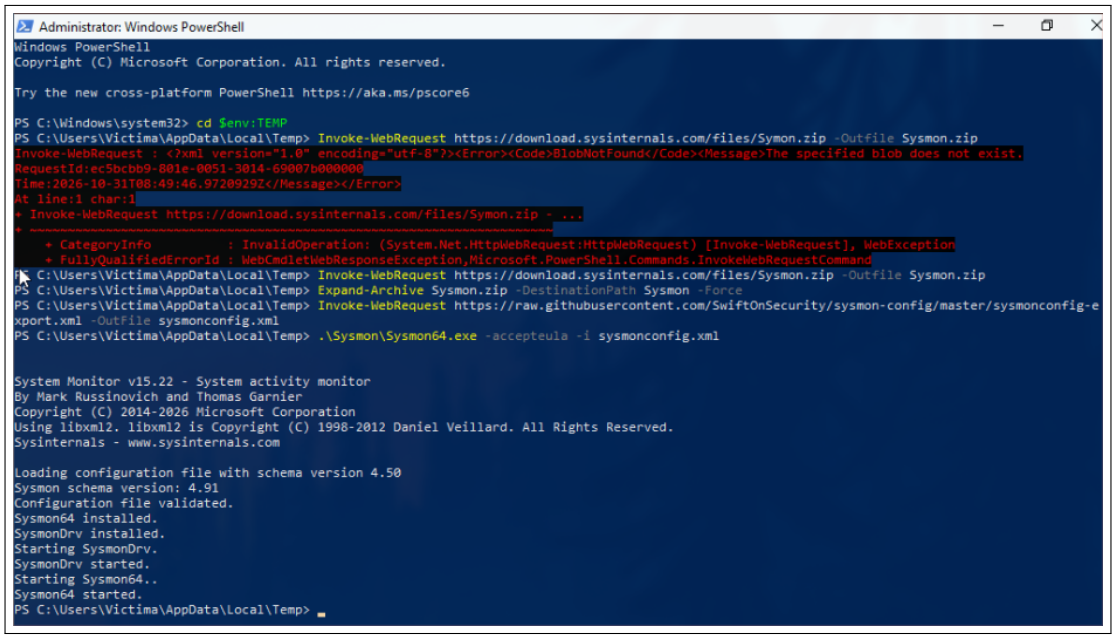


Figura A.18: Instalación de Sysmon

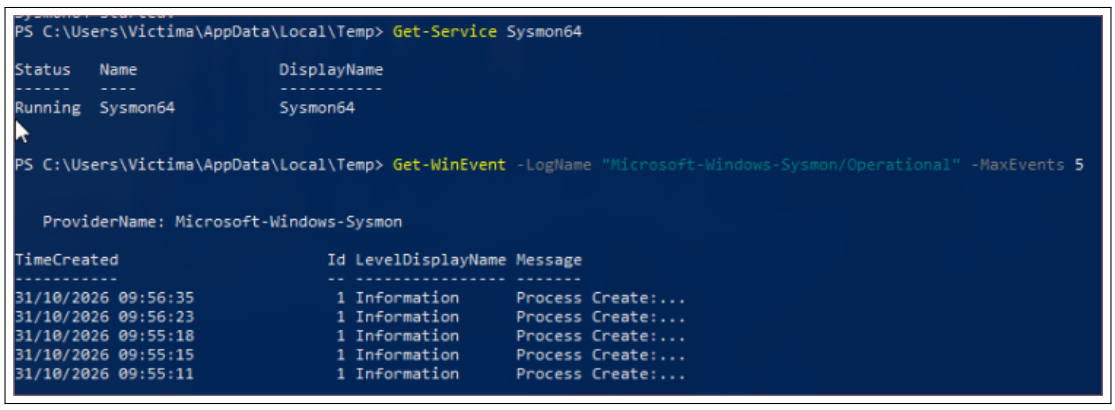


Figura A.19: Servicio Sysmon64 en ejecución y primeros eventos

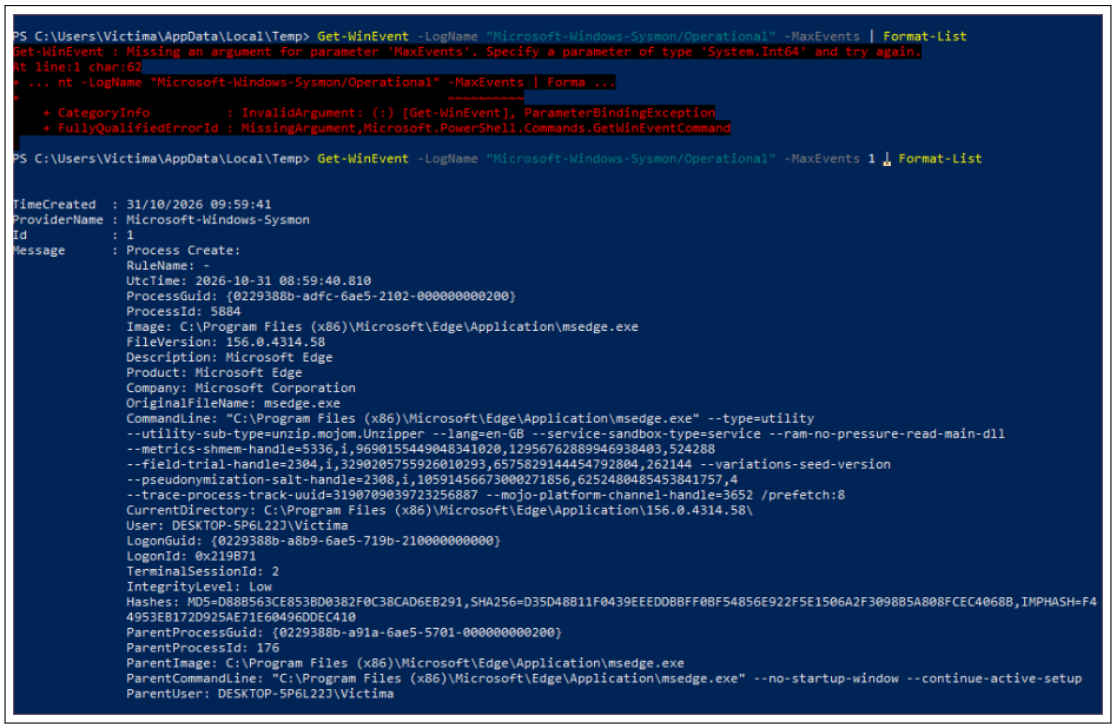


Figura A.20: Evento Sysmon ID 1 (creación de proceso) en detalle

A.4.2 OpenSSH Server

Se habilita OpenSSH en Windows para disponer de una superficie de ataque remota (escenario 4.2).

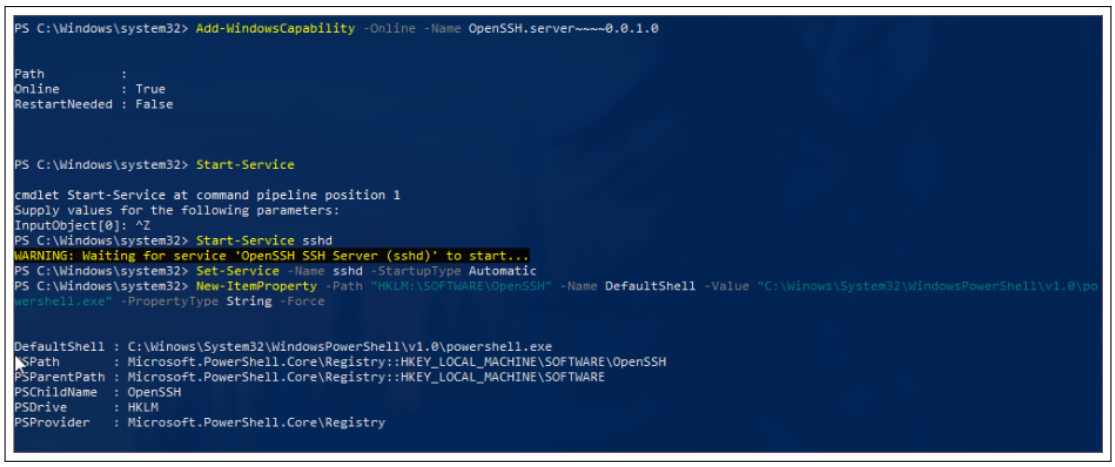


Figura A.21: Instalación y arranque de OpenSSH Server con PowerShell como shell por defecto

A.4.3 Agente Wazuh

Listado A.5: Instalación del agente Wazuh en Windows

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.9-1.msi ‘
  -OutFile $env:tmp\wazuh-agent
msiexec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER=’10.10.10.10’ WAZUH_AGENT_NAME=’windows10’

NET START Wazuh
```

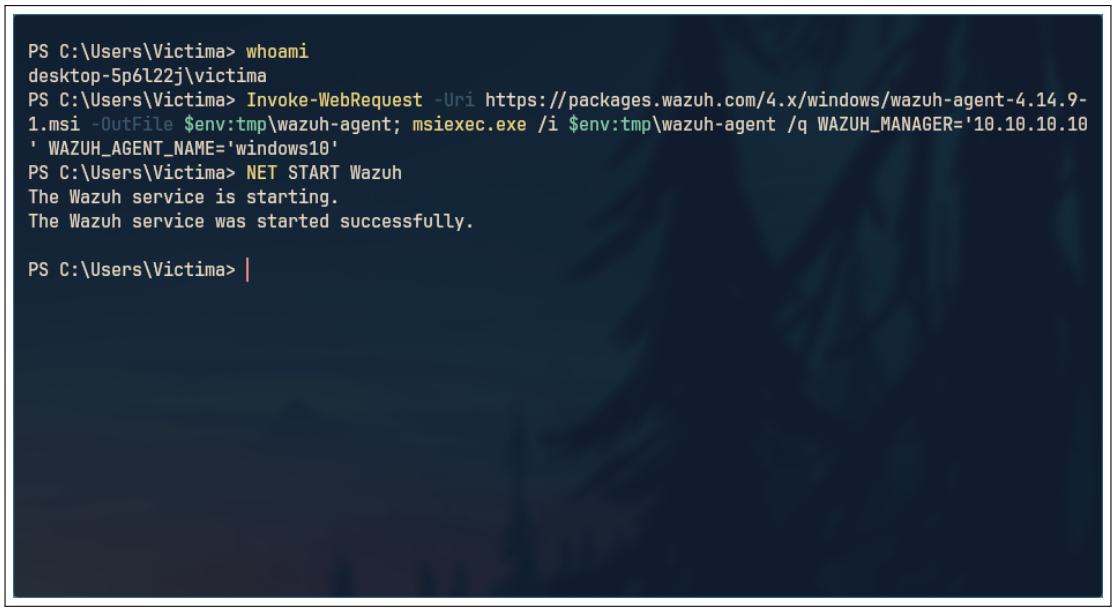


Figura A.22: Agente Wazuh instalado y arrancado

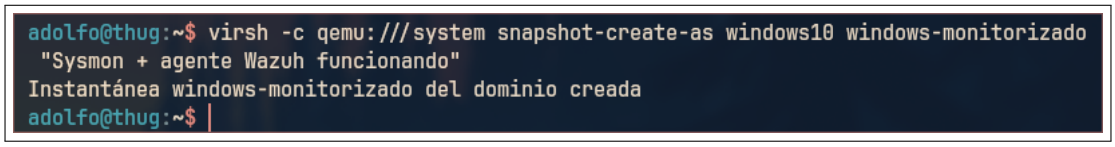


Figura A.23: Instantánea windows-monitorizado

Pendiente

Añade cómo se ingesta el canal de Sysmon en el agente (ossec.conf, Microsoft-Windows-Sysmon/Operational) si lo configuraste.

A.5 Suricata en OPNsense e integración con Wazuh

Suricata se activa en modo IDS (PCAP live) sobre la interfaz LAN, en modo promiscuo, con los siguientes conjuntos de reglas:

- Reputación / listas negras: abuse.ch SSL Fingerprint Blacklist, SSL IP Blacklist, ThreatFox, URLhaus; ET open botcc, compromised y drop.
- Detección de ataques: ET open emerging-attack_response (imprescindible para la prueba de testmynids.org), emerging-scan, emerging-exploit, emerging-malware, emerging-policy, emerging-dns y emerging-web_client.

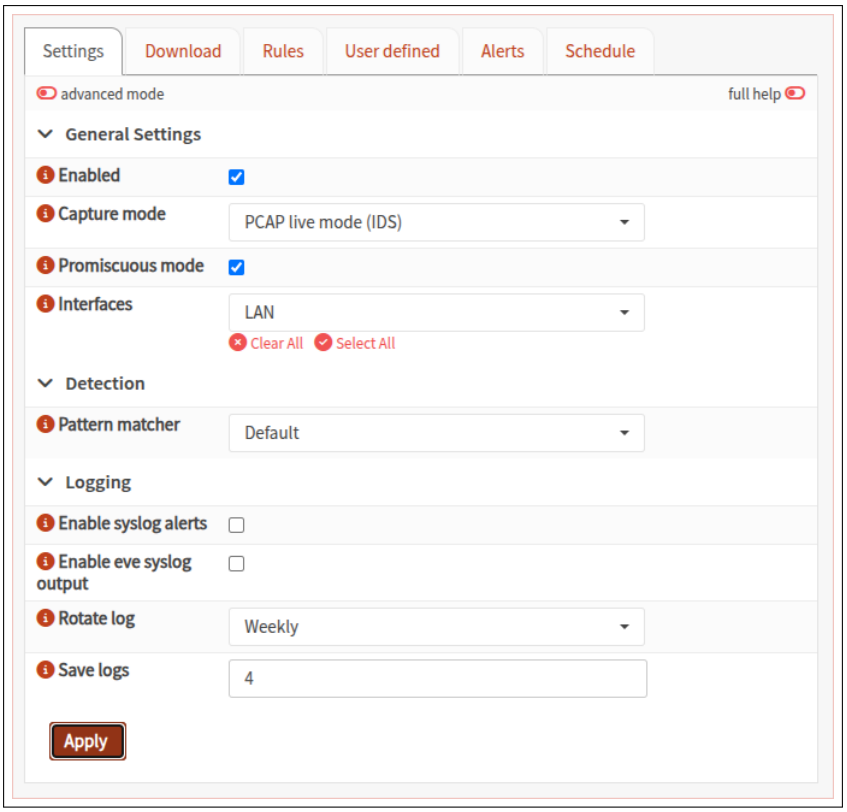


Figura A.24: Ajustes generales de Suricata en OPNsense

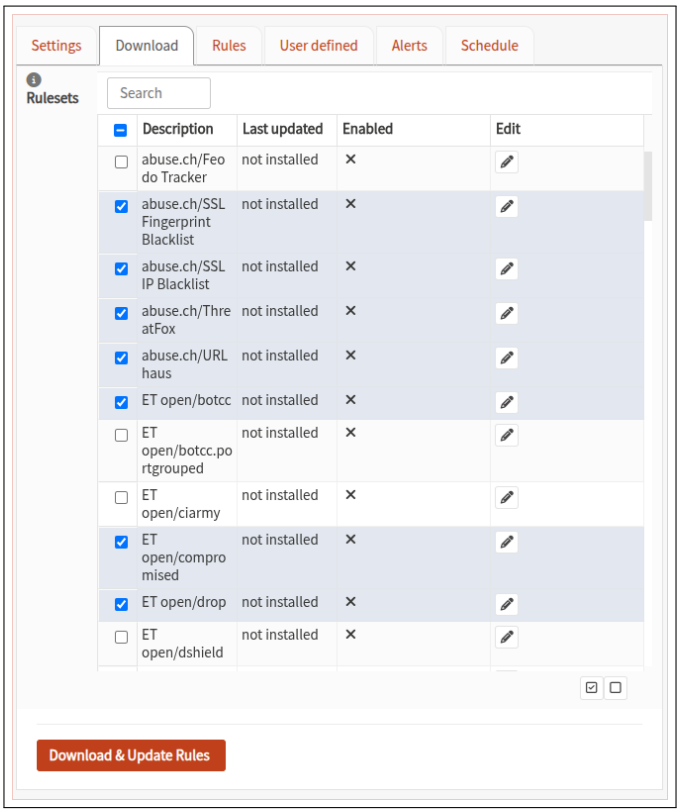


Figura A.25: Selección de rulesets

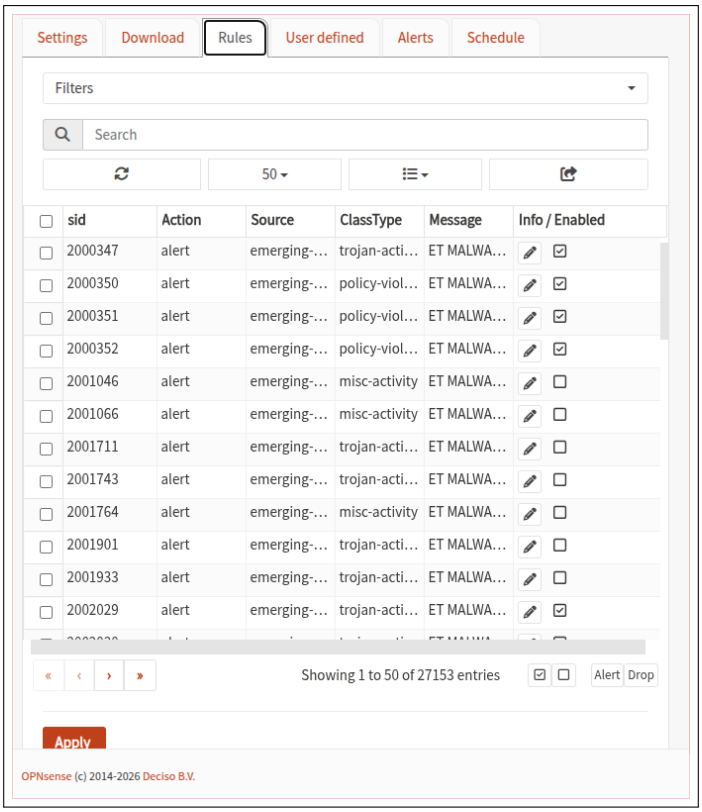


Figura A.26: Reglas cargadas tras descargar los conjuntos

Para que las alertas de Suricata lleguen al SIEM se instala el plugin os-wazuh-agent en OPNsense.

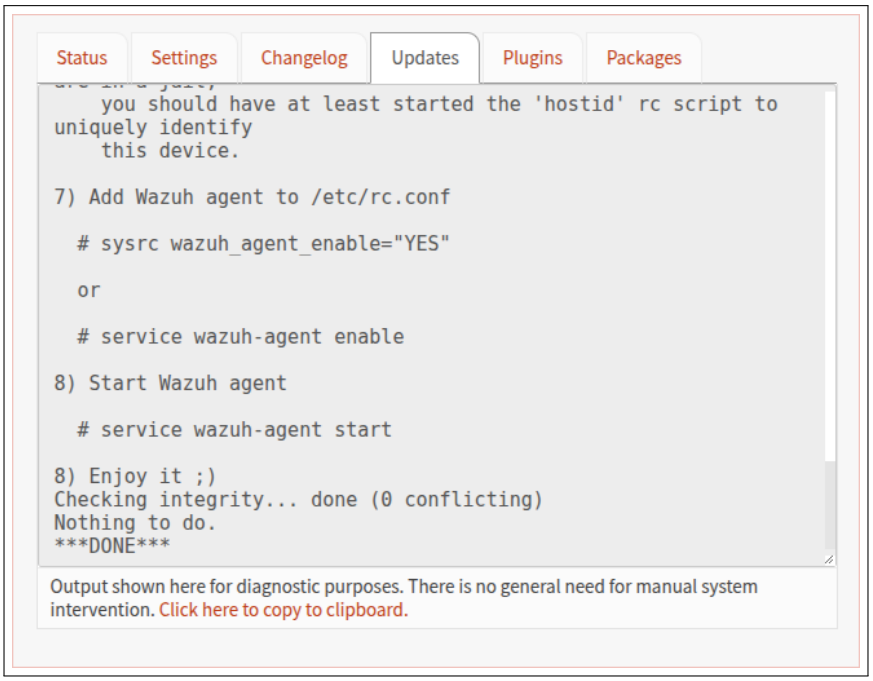


Figura A.27: Instalación del plugin os-wazuh-agent

A.6 Víctima Linux: Ubuntu Server

Listado A.6: Creación de la VM ubuntu-victima

```
virt-install --connect qemu:///system \
  --name ubuntu-victima --memory 2048 --vcpus 1 \
  --disk size=15,bus=virtio \
  --cdrom /var/lib/libvirt/images/ubuntu-26.04.1-live-server-amd64.iso \
  --network network=soc-lab,model=virtio \
  --osinfo detect=on,require=off --graphics spice --noautoconsole
```

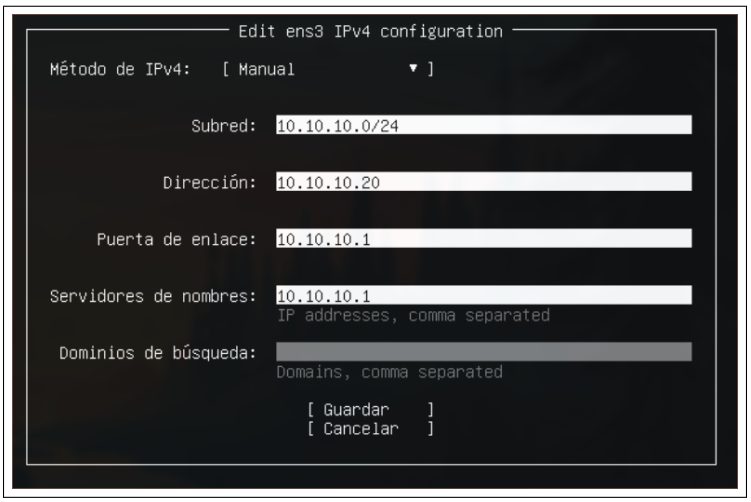


Figura A.28: IP estática 10.10.10.20 en ubuntu-victima

Pendiente

Documenta la instalación del agente Wazuh en ubuntu-victima.

A.7 Red de ataque y Kali Linux

La máquina atacante se coloca en una red propia (attack, 10.10.20.0/24) conectada a una tercera interfaz de OPNsense, para que todo su tráfico hacia las víctimas pase por el cortafuegos y por Suricata.

Listado A.7: Definición de la red attack

```
cat > attack.xml <<'EOF'
<network>
  <name>attack</name>
  <bridge name="virbr-attack"/>
</network>
EOF
virsh -c qemu:///system net-define attack.xml
virsh -c qemu:///system net-autostart attack
virsh -c qemu:///system net-start attack
```

```
adolfo@thug:~$ cat > attack.xml <<'EOF'
<network>
  <name>attack</name>
  <bridge name="virbr-attack"/>
</network>
EOF
virsh -c qemu:///system net-define attack.xml
virsh -c qemu:///system net-autostart attack
virsh -c qemu:///system net-start attack
La red attack se encuentra definida desde attack.xml

La red attack ha sido marcada para iniciarse automáticamente

La red attack se ha iniciado
```

Figura A.29: Creación de la red attack

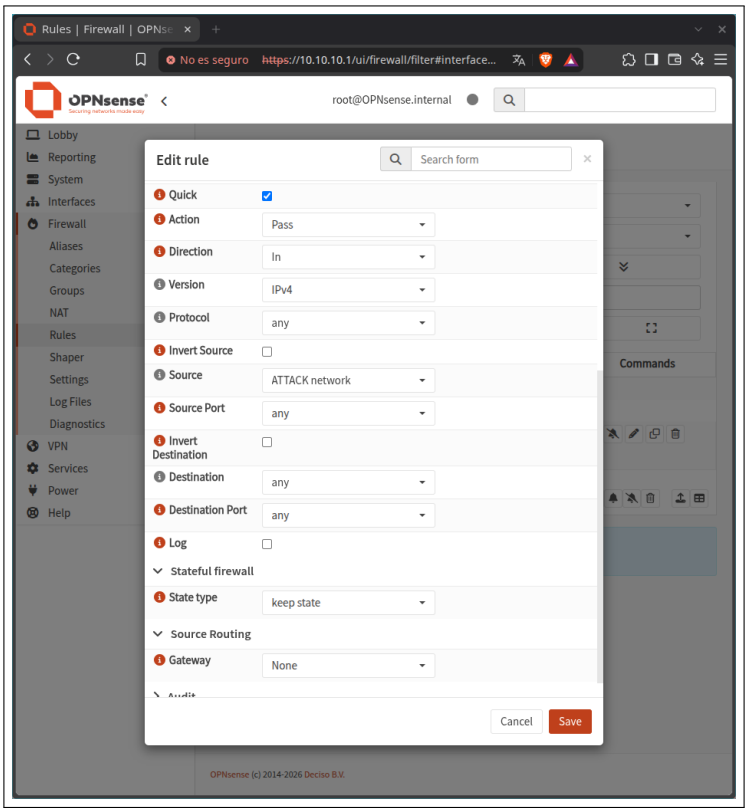


Figura A.30: Regla de cortafuegos para la red ATTACK en OPNsense

Listado A.8: Configuración de red estática en Kali

```
sudo nmcli con mod "Wired connection 1" ipv4.method manual \
  ipv4.addresses 10.10.20.10/24 ipv4.gateway 10.10.20.1 ipv4.dns 10.10.20.1
sudo nmcli con up "Wired connection 1"
```

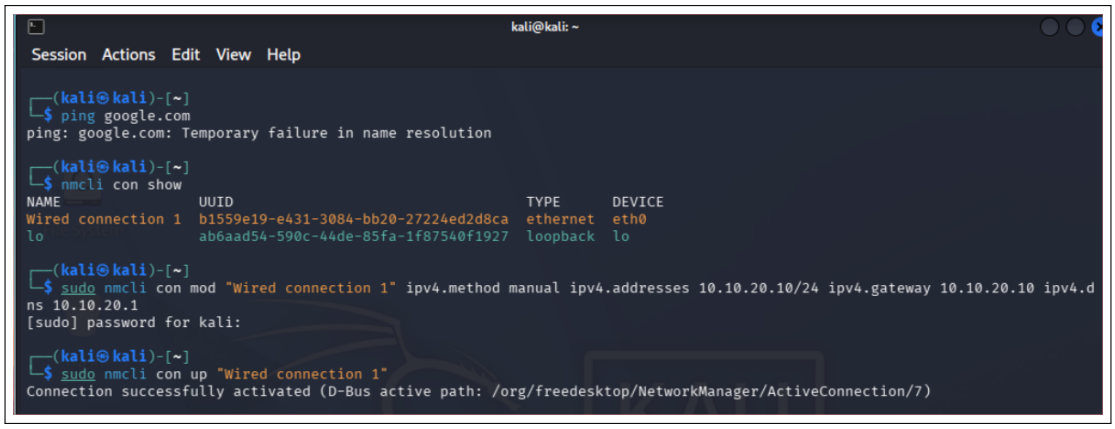


Figura A.31: Configuración de red en Kali

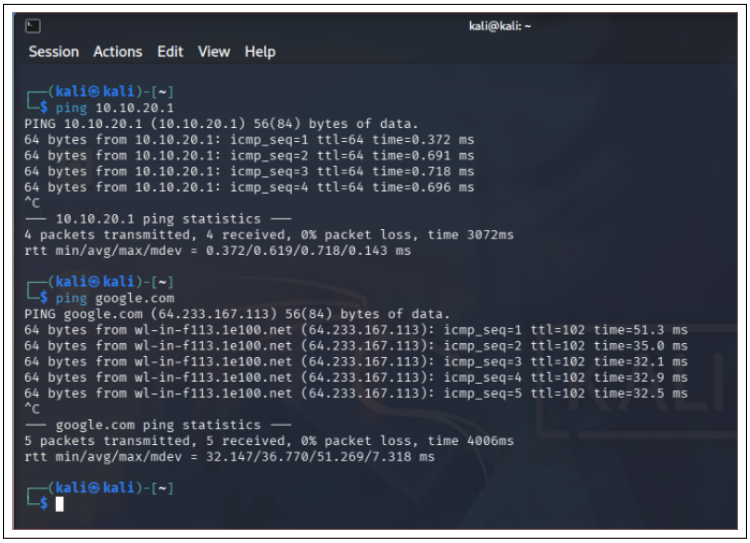


Figura A.32: Kali alcanza su puerta de enlace e Internet a través de OPNsense

Pendiente

La regla actual permite todo el tráfico desde ATTACK. Decide y documenta qué tráfico se permite hacia la LAN para cada escenario.

B | Comandos de gestión del laboratorio

Listado B.1: Gestión de VM con virsh

```
# Arrancar máquinas
virsh -c qemu:///system start opnsense
virsh -c qemu:///system start windows10

# Ver máquinas encendidas y apagadas
virsh -c qemu:///system list --all

# Abrir visor gráfico
virt-viewer -c qemu:///system --reconnect windows10 &

# Crear instantánea
virsh -c qemu:///system snapshot-create-as windows10 windows-monitorizado \
  "Sysmon + agente Wazuh funcionando"

# Borrar instantánea
virsh -c qemu:///system snapshot-delete windows10 windows-limpio
```

C | Configuraciones

Los ficheros completos están en la carpeta configs/ del repositorio. Aquí se incluyen solo los fragmentos relevantes.

C.1 Red attack de libvirt

Listado C.1: configs/libvirt/attack.xml

```
<network>
  <name>attack</name>
  <bridge name="virbr-attack"/>
</network>
```

C.2 Agente Wazuh en Windows

Pendiente

Fragmento de ossec.conf con el localfile del canal Microsoft-Windows-Sysmon/Operational.

C.3 Reglas locales de Wazuh

Pendiente

Contenido de local_rules.xml cuando crees reglas propias.